

ASHAKids — Despliegue y auditoría HTTPS

Corte 2026-10-09-15. Fecha:9oct2026,20:43–20:50 America/Lima (UTC10 oct). Responsable técnico: asistente bajo autorización de Piero. Repositorio: <https://github.com/sromansilva/ashakids-platform> .

Runtime auditado: dev, V24, SHA 62905fc0480fffd21fb6b2d969592700608d64bb. Trabajo: piero-dev con modificación explícita del provisionador SCRAM; cierre documental V25. El SHA de la imagen precede al commit del informe. Entrega académica indicada:9oct18:00 Lima; ejecución posterior a ese horario.

01. Dictamen ejecutivo

AshaKids está publicada en <https://ashakids.onrender.com>, Render Free Virginia, Docker con React/FastAPI bajo el mismo origen y Supabase existente. Estado Live y buildLinux57.9 s observados. La nueva cohorte pasó 101 respuestas HTTPS esperadas y ocho comprobaciones públicas adicionales; lectura posterior confirmó persistencia y cero sesiones auth nuevas sin revocar.

Indicador	Resultado nuevo	Evidencia
Hosting	Live; un worker; dev; despliegue manual	render-live.png, render-startup.txt
Recorrido sintético	101 esperadas; 0 fallos; 10 cookies seguras	https-journey.json
Smoke público	8 respuestas esperadas	https-smoke.json
Persistencia	2 citas/2 sesiones/1 reporte/2 mensajes	persistence.json
Privilegios/TLS	runtime; TLS 1.3; cadena/hostname verificados	pooler-tls.json

No se recalcula una puntuación técnica ni se declara certificación de producción. No se alteraron cuentas o clínica preexistentes, ni se ejecutaron TRUNCATE/borrados físicos. Los casos usan seis usuarios nuevos identificados AUDITORIA.

02. Arquitectura y cambios realizados

React -> HTTP/JSON -> FastAPI -> SQLAlchemy/PostgreSQL. Node22 compila el frontend; Python3.13 sirve la SPA y API en la misma imagen. PostgreSQL permanece en Supabase; pooler oficial de sesión 5432 con IPv4 y ashakids_runtime. Sin Supabase Auth, acceso SQL desde React, nuevas tablas o semillas al arrancar.

Servicio: srv-db4penqjnfac7382hjhg. Deploy: dep-db4peo2jnfac7382hl20. Región: Virginia. ENVIRONMENT=production, WEB_CONCURRENCY=1, FORWARDED_ALLOW_IPS=127.0.0.1,::1. DB_SSL_CA_FILE=/etc/secrets/prod-ca.crt; CA oficial2021, DB_SSL_LEGACY_CA=true por formato antiguo; verificación TLS activa. Credencial runtime guardada solo como secreto autorizado en Render.

Cambio de este corte: verificador SCRAM del único rol nuevo 32768->4096, conservando contraseña aleatoria y permisos, y valor 4096 en apply_b02_runtime_role.py. ADR0012 registra compatibilidad y riesgo. El esquema/PK/FK del corte 14 es evidencia heredada, no una nueva inspección integral. Las operaciones de este corte confirmaron relaciones paciente/tratamiento/reserva/sesión/reporte y conversación/mensaje mediante sus IDs nuevos.

03. APIs funcionando: identidad y pacientes

Caso HTTPS	Permiso observado	Resultado
POST auth/login; GET auth/me	ADMIN, PADRE, TERAPEUTA sintéticos	200; cookie Secure/HttpOnly/Lax
Alta de cuentas/perfiles	ADMIN sintético	201; IDs nuevos 72..77
Lectura/actualización paciente/tratamiento	Responsable/asignado	200; persistencia confirmada
Lectura ajena	Otra familia/profesional	Rechazo esperado; sin payload clínico en evidencia
Suspensión/reactivación de padre nuevo	ADMIN sintético	Sesión revocada; reactivar no la revive
POST logout con origen ajeno	Nueva sesión ADMIN	403; auth/me posterior 200
Logout final	Todas las sesiones sintéticas	200; SQL 0 sin revocar

El ADMIN existente se autenticó únicamente en ASGI local para dar de alta un seed ADMIN nuevo y cerró esa sesión. Su contraseña nunca se envió a Render. La cadena de101 respuestas procede del hosting; el bootstrap local previo no se suma a esa cifra. Diez logins HTTPS comprobaron flags de cookie sin guardar su valor.

Pacientes 95/96, tratamientos 15/16 y usuarios 72..77 pertenecen a AUDITORIA_RENDER_20261010_014323. Desactivación de paciente 96 fue lógica y posteriormente reactivada; no DELETE físico. No se tocaron familias o pacientes anteriores.

04. APIs funcionando: citas, sesiones y sistema

Caso	Estado/concurrencia observada	Persistencia
Reserva simultánea	201+409; sesiones auth distintas	2 reservas 12/13 en cohorte
Creación de sesión simultánea	201+409	2 sesiones 11/12
Inicio/cierre simultáneos	200+409 en ambas transiciones	Ambas FINALIZADA
Ausencia/repetición de cierre	Cierre aceptado; repetición 409	Sesión12 finalizada
Escritura concurrente de reporte	Un reporte completo; último escritor	Sesión11; persistencia tras relogin
Conversación/mensajes	Chat concurrente con mismo ID	Chat 6; 2 mensajes
Reporte PDF autorizado	Descarga válida	reporte-sintetico.pdf
/health y /health/ready	200 y200	Readiness comprueba conexión

Smoke independiente: HTML raíz/login 200, asset y API inexistentes 404, auth/me sin sesión 401, login vacío 422. Readiness no certifica por sí sola esquema completo ni recorrido funcional; estos se apoyan en la cohorte API y lectura SQL. React/dist se construyó en Linux; no equivale a revisar todas las pantallas.

05. APIs no operativas y capacidades faltantes

No se encontró una operación rota dentro del recorrido ejecutado. Rechazos 401/403/409/422 esperados son validación y control de acceso, no fallos de la API. El alcance no cubre el complemento de todas las operaciones del corte 14.

Capacidad	Estado real	Siguiente acción
Despertar del plan gratuito	Panel advierte 50 s o más	Abrir URL antes de demo
Backup/restauración y caída real	No ensayados	Plan separado con responsable
Carga/expiración natural	No ensayadas	No inferir capacidad/TTL real
Todas las pantallas/dispositivos	Sin nueva QA exhaustiva	Mantener evidencia heredada separada
Rotación de cuentas existentes	Fuera de autorización	Coordinar cuando corresponda
Pagos	Excluidos por profesor	Sin implementación nueva

Auto Deploy Off: publicar documentación no actualiza la imagen. No hay despliegue anterior para rollback en esta primera publicación. Disco de Render efímero; los datos verificados se guardan en Supabase. No se creó otra BD, servicio de pago o pasarela.

06. Seguridad y riesgos priorizados

Prioridad	Hallazgo/resultado	Acción y límite
Seguimiento	Supavisor 2.9.10 anuncia 4096; catálogo previo 32768	Recalculado solo runtime con aprobación
Riesgo asumido	Derivación 4096 cuesta 8 veces menos offline	Contraseña 64 caracteres aleatoria; subir coste al corregir pooler
Verificado	Atributos/ACL/RLS/membresías/propietarios idénticos	Huellas antes/después; sin permisos antiguos alterados
Verificado	TLS 1.3,CERT_REQUIRED,hostname; CA explícita	Sin fallback TLS ni MD5
Verificado	Cookie segura; origen ajeno 403; suspensión/logout	Solo cuentas nuevas; sin pentest
Límite heredado	RLS técnico USING true; autorización en API	No aislamiento familiar mediante RLS SQL
Límite heredado	Limitador login en memoria	Un worker/instancia; no certifica escalado

Fallos iniciales de CA y SCRAM resueltos; un rechazo transitorio tras el ajuste precedió al login exitoso. El respaldo del verificador permanece privado. Hashes de usuarios de la aplicación y funciones ADMIN conservados. Fuente oficial Supavisor y mecanismo documentados en ADR0012. El endpoint directo no resolvía en esta red; el pooler usa certificados verificados.

07. Evidencia de validación y límites

Comando/caso ejecutado	Entorno	Resultado/evidencia
tmp/verify_render_journey.py	HTTPS Render/Supabase real	101 esperadas; 0 fallos; https-journey.json
tmp/verify_render_http.py	HTTPS sin identidad	8 respuestas; https-smoke.json
tmp/verify_render_persistence.py	SQL READ ONLY runtime	Conteos esperados; 0 sesiones auth
tmp/verify_render_pooler.py	Pooler oficial5432	Rol/TLS comprobados; pooler-tls.json
tmp/adjust_runtime_scram.py	Rol nuevo autorizado	Hash recalculado; huellas iguales
knowledge/manage.py refresh/check	AST local sin LLM	Vigente; fallback secuencial WinError5
Actions 38002334489/38002334516	GitHub,V24	Dos jobs graph success; no suite clínica

Guiones de aceptación equivalentes conservados en docs/evidence/audit-2026-10-09-15/ con instrucciones y entrada privada. verify-journey.py requiere --execute-authorized y crea otra cohorte: leer advertencia antes de repetir. Ningún secreto forma parte del guion/reporte.

Rúbrica recibida	Evidencia de este corte	Límite
Arquitectura/backend	Docker real y API HTTPS	Sin criterio/puntuación inventados
BD/relaciones/operaciones	Conteos SQL y relaciones de cohorte	Modelo integral del corte 14 heredado
Seguridad/usuarios/permisos	Cookies/orígenes/rol/TLS/huellas	Sin pentest ni datos anteriores modificados
Pruebas funcionales/no funcionales	Roles/concurrencia/errores esperados	No carga ni recuperación

Heredado, no ejecutado nuevamente: V24 reportó138 pruebas backend sin BD/19 avisos, typecheck/build React y11 smoke ASGI. No sumar esos resultados a las101 respuestas nuevas. CI graph solo comprueba mapa AST. Se omiten DELETE físicos, suites con TRUNCATE y QA completa del navegador. No se publican capturas con datos reales.

08. Cierre y ruta de entrega

URL: https://ashakids.onrender.com. Usar login habitual y abrir el servicio unos minutos antes de presentar. Render Free puede suspenderse; no programar pings para eludir restricciones. El ADMIN mantiene sus funciones; B02 limita el usuario SQL del backend.

Fuente: docs/audits/auditoria-2026-10-09-15.md. PDF: output/pdf/Auditoria_Despliegue_AshaKids_2026-10-09-15.pdf. Evidencia y manifest: docs/evidence/audit-2026-10-09-15/. Cierre previsto V25_Despliegue_HTTPS_Seguridad_Backend en dev y feat/piero-dev; verificar publicación y SHA al finalizar. La imagen funcional permanece V24 por deploy manual.

Conservar usuarios 72..77/pacientes 95,96/tratamientos 15,16/reservas 12,13/sesiones 11,12/chat 6. Cero sesiones auth nuevas sin revocar confirmado 20:49 Lima. Recuperación, carga, expiración natural y revisión visual completa permanecen no ensayadas.